

MY CYBER ACADEMY

Session 9 of 14

CREST Practitioner Intrusion Analyst (CPIA)

Analysing Host Intrusions I: Acquisition & Lab Setup

From seizing a device under ACPO to a hardened analysis lab and the Windows file system.

GROUP E | ACQUISITION | LAB SETUP | WINDOWS FS

© Billy Forrest

Fourteen sessions, six knowledge groups

Knowledge Group	Focus	Sessions
A · Soft Skills & Incident Handling	Engagement, chronology, law, threat	1
B · Core Technical Skills	Protocols, tools, fingerprinting, crypto, host analysis	2–4
C · Background Info Gathering & OSINT	WHOIS, DNS, open-source investigation	5
D · Network Intrusion Analysis	Capture, logs, C2, exfiltration, attacks	6–8
E · Analysing Host Intrusions	Acquisition, Windows FS, registry, memory, malware	9–11
F · Reverse Engineering Malware	Anti-RE, PE format, obfuscation, behaviour	12–14

© Billy Forrest

KNOWLEDGE GROUP E · SKILL AREAS

Session 9 covers E1, E2 and E3

Ref	Skill area	Assessment
E1	Host-based Data Acquisition	MC
E2	Live Analysis Laboratory Set-up	MC
E3	Windows File System Essentials	MC
E4	Windows File Structure	MC P
E5	Application File Structures	MC P
E6	Windows Registry Essentials	MC P

© Billy Forrest

SESSION OBJECTIVES

By the end of this session you will be able to

- **Apply the ACPO principles** to seizure, preservation and examination of evidence
- **Perform host-based acquisition** with write blockers and forensic imaging tools
- **Verify image integrity** using MD5 and SHA1 computed hashes
- **Stand up a live analysis lab** with a grab pack and hardened sandboxes
- **Explain disk partitioning and file systems** FAT and NTFS, and their core structures
- **Describe ACLs, SIDs, unallocated space** and EFS and BitLocker encryption

© Billy Forrest

Host-based data acquisition — the fundamentals

- **Static and dynamic gathering** dead-box imaging versus live evidence capture
- **Image formats** raw (dd), E01/EWF and others used by forensic tools
- **Local acquisition** a write-blocked drive imaged on the bench
- **Remote acquisition** imaging a live host across the network
- **Core objective** a bit-for-bit copy whose integrity can be proven

© Billy Forrest

ACPO Principle 1

- **Principle 1** no action taken by Police or their agents should change data held on a computer or other storage media which may subsequently be relied upon in Court
- **Isolate the device** remove it from the network at seizure
- **Turn the device off** at the point of seizure where appropriate
- **Consider local policies** before powering down
- **Mobiles and tablets** place in a shielded Faraday container
- **Use forensic software** and plan the examination to avoid data loss

© Billy Forrest

The Faraday bag

- **Purpose** prevents a handset communicating with a mobile phone network
- **Battery drain** a handset inside a Faraday bag depletes rapidly
- **Correct sealing** fold the top of the bag over, otherwise the signal may not be blocked
- **Wipe mode risk** remote-wipe commands cannot reach a shielded device

© Billy Forrest

ACPO Principles 2, 3 and 4

1

Principle 2

in exceptional circumstances a competent person may access original data, and must be able to explain their actions

2

Principle 3

an audit trail or record of all processes applied to the evidence must be created and preserved

3

Principle 4

the case officer (OIC) is responsible for ensuring the law and these principles are adhered to

© Billy Forrest

Seizure and the audit trail

- **Photograph the scene** record the status of the exhibit at the point of seizure
- **Record on / off state** and the condition of the exhibit
- **Maintain a log** of every action taken with the exhibit
- **Record changes of data** e.g. accidental changes during acquisition
- **Note tools and versions** including product names and version numbers
- **Exhibit continuity** seizing personnel trained and equipped for the task

© Billy Forrest

Imaging prerequisites — the jump kit

- **Write blocking device** a hardware write blocker stops writes to the source
- **Data and power cables** adaptors for the range of target drives
- **Forensic imaging software** FTK Imager, dd, ddrescue, DEFT
- **Verification hashes** MD5 and SHA1 computed and compared
- **Clean media** target drives ready for the image

© Billy Forrest

Imaging with FTK Imager and ddrescue

- **FTK Imager** GUI-based imaging with computed MD5 and SHA1 checksums
- **Image verification** checksums recomputed and compared after acquisition
- **Hash mismatch** a mismatch invalidates the image and requires re-acquisition
- **DEFT** a Linux live forensic distribution used at the bench
- **ddrescue** recovers data from failing media; -n writes only good sectors, -d uses direct disk access on error areas

© Billy Forrest

DISCUSSION

A seized laptop cannot be turned off safely at the point of seizure. What are the risks, and how would ACPO Principle 2 guide your actions?

Consider volatile data, full-disk encryption, and the need for a competent person to explain any change to the original data.

Every exception to Principle 1 must be justified by a competent examiner who can account for their actions.

© Billy Forrest

Standing up a live analysis laboratory

- **The grab pack** hardware, software, cabling and incident checklists
- **Hardware** write blockers, SATA/PATA/IDE/SCSI adaptors, imaging laptop, storage drives
- **Network infrastructure** an isolated or controlled lab network
- **Documentation** incident checklist, call lists, communication plan
- **Best practice** virtualise — fewer machines, snapshots, easy to clean

© Billy Forrest

Virtualisation versus standalone machines

Approach	Advantages	Disadvantages
VMware server (free)	Less dedicated machines; snapshots; host-only networking; easy to clean	Complicated to configure; needs lots of RAM; detectable by malware
Multiple standalone machines	Fast to set up; accurately reflects the original; hard to mis-set-up	Expensive; requires dedicated network infrastructure

© Billy Forrest

Host hardening and the sandbox

- **What hardening is** increasing defences, decreasing ease of infiltration, limiting malware spread
- **Why harden** prevent further infections and protect the analysis lab
- **Methods** passwords and firewalls; low privileges, elevating as needed
- **Air-gapped network** physically isolated from the corporate estate
- **Sandbox environments** a complex network of replicable machines, normally VMs
- **Disposable and realistic** easily re-set or rolled back, difficult to break out of

© Billy Forrest

Lab setup process and tooling

1. **Build the VMs**
   install multiple VMs to simulate the infected network; install OSs and applications
2. **Simulate the environment**
   web host, DNS, FTP and file servers as needed
3. **Snapshot**
   take a clean snapshot before installing service packs and patches
4. **Install analysis tools**
   hash tools, rootkit identifiers; verify tool integrity
5. **Snapshot again**
   then begin behaviour and code analysis
6. **Re-hash and compare**
   verify tools have not been altered during the analysis

© Billy Forrest

Booting to an image

- **Pros** realistic and fast — boots the acquired image directly
- **Cons** licensing issues and cost; the image must be capable of booting
- **Behaviour analysis tools** system information, process monitoring, file monitors, registry monitors
- **More robust than Task Manager** specialist process-monitoring tools give deeper visibility
- **Do not remove malware yet** virus and rootkit scanners identify but do not clean at this stage
- **Use multiple tools** cross-check with ADS viewers, port scanners, hex editors

© Billy Forrest

Disk partitioning and file systems

- **Partitioning** tasks to create, resize and delete partitions; logical segments of a physical device
- **MBR limit** only room for four partition entries in the master boot record
- **Partition types** primary, extended and logical partitions overcome the limit
- **File systems** organise files on hard discs, USB drives and tapes
- **FAT and NTFS** FAT12/16/32 for older and removable media; NTFS is the modern Windows default

© Billy Forrest

FAT and the directory entry

- **Directory entries** tell where the first cluster of a file is located
- **Entry metadata** name, file size, extension, attributes, date and time
- **Two FAT copies** FAT1 and FAT2 protect against table corruption

Variant	FAT entry	Max clusters	Max volume
FAT12	12 bits	~4,086	16 MB
FAT16	16 bits	~65,536	2 GB
FAT32	28 bits	~268,435,456	2 TB

© Billy Forrest

NTFS, the MFT and attributes

- **NTFS** Microsoft's high-performance, reliable and secure file system
- **Features** access control lists and the encrypted file system
- **Master File Table ($MFT)** stores file metadata as attributes
- **Resident attributes** $STANDARD_INFORMATION, $FILE_NAME, $DATA
- **Non-resident attributes** $BITMAP and others held outside the MFT record
- **$MFT and $Bitmap** the metadata and allocation tables of the volume

© Billy Forrest

ACLs, SIDs, unallocated space and encryption

- **Access Control Lists** a list of permissions attached to an object — file and share permissions
- **Grants access** to users and system processes
- **Security Identifiers (SIDs)** uniquely identify users and groups; listed via the registry ProfileList or WMIC
- **Unallocated space** deleted files can be recovered here by carving
- **EFS** encrypts files on NTFS using the username and password plus DES or AES
- **BitLocker** AES 128/256-bit volume encryption; manage-bde -status reveals volumes

© Billy Forrest

KEY TAKEAWAYS

- **ACPO frames acquisition** four principles govern seizure, examination and the audit trail
- **Seize and preserve** write blockers, Faraday bags and bit-for-bit images with verified hashes
- **Virtualise the lab** hardened, snapshot-able sandboxes beat expensive standalone machines
- **Know the file system** partitioning, FAT entries, NTFS $MFT, ACLs and SIDs
- **Encryption matters** EFS and BitLocker change what you can acquire and how

© Billy Forrest

QUIZ

Consolidation quiz (Group E: acquisition, lab, FS)

- Which ACPO principle demands an audit trail of all processes applied to evidence?
- What does a hardware write blocker prevent?
- Which FAT variant is most commonly found on removable media?
- Where in NTFS is file metadata stored as attributes?
- What does manage-bde -status reveal?

Answers in the session quiz — aim for 70%+ before leaving.

© Billy Forrest

NEXT SESSION

Next session: Analysing Host Intrusions II

- Windows file structure: Prefetch, shadow copies, pagefile and hibernation
- Application file structures and identifying suspect files
- Windows registry essentials and storage media
- Memory analysis with the Volatility framework

Reading: Knowledge Group E source material.

© Billy Forrest



MY CYBER ACADEMY

Session 10 of 14

CREST Practitioner Intrusion Analyst (CPIA)

Analysing Host Intrusions II: Windows FS, Registry & Memory

The file structure, application artefacts, registry, suspect files, storage media and memory analysis.

GROUP E | FILE STRUCTURE | REGISTRY | MEMORY

© Billy Forrest

Session 10 covers E4 to E9

Ref	Skill area	Assessment
E4	Windows File Structure	MC P
E5	Application File Structures	MC P
E6	Windows Registry Essentials	MC P
E7	Identifying Suspect Files	MC P
E8	Storage Media	MC
E9	Memory Analysis	MC

© Billy Forrest

SESSION OBJECTIVES

By the end of this session you will be able to

- **Interpret Windows file-structure artefacts** Prefetch, shadow copies, pagefile, hibernation
- **Analyse application file structures** archives, browsers, PE files, Office, PDF, email
- **Work with the Windows registry** its hives and the keys that reveal persistence
- **Identify suspect files** using hash tables, strings and signature analysis
- **Handle the range of storage media** and the write-blocking and imaging concerns
- **Analyse memory with Volatility** processes, DLLs, sockets and network connections

© Billy Forrest

Windows Prefetch

- **Purpose** Prefetch speeds application startup by pre-loading code and data
- **Location** %SYSTEMROOT%\Windows\Prefetch, with a .pf extension
- **Contents** application name, location, files used, launch count
- **Timestamps** time and date of the last launch
- **Forensic value** reveals programs run and supports a timeline of execution
- **Anti-forensic signs** can help identify potential intrusions and wiping activity

© Billy Forrest

User profiles and temporary files

- **User profiles** files, folders, configurations and settings for a user account
- **Local vs roaming** local is device-bound; roaming is copied and synced from the server
- **Locations** XP uses Documents and Settings; Vista/7/8/10 use Users
- **Temporary files** %SystemRoot%\Windows\Temp; names often start with ~ and end .tmp
- **Office tmp files** used for editing, document recovery and printing services

© Billy Forrest

Restore points and volume shadow copies

- **System Restore Points** backups of vital configurations and files, not user data
- **Restore location** %SystemRoot%\System Volume Information
- **Volume Shadow Copies (VSS)** snapshots of volumes for backing up system and user files
- **vssadmin list shadows** lists shadow copies for a given volume
- **mklink /D** mounts a shadow copy to a directory for access
- **ShadowExplorer** browses and exports the contents of shadow copies

© Billy Forrest

Hosts file, pagefile and hibernation

- **Hosts file** an address book linking hostnames to IP addresses; vulnerable to hijacking
- **Hosts location** %SystemRoot%\System32\drivers\etc; hidden in Explorer
- **Pagefile.sys** used as virtual RAM when the system is low on memory
- **Hibernation file** hiberfil.sys preserves the running state without power
- **Acquisition** specialist tools and data carving extract their contents
- **Volatility** used to convert and analyse hibernation file contents

© Billy Forrest

Shimcache, recycle bin and event logs

- **Shimcache (AppCompatCache)** tracks program execution; less reliable than Prefetch
- **Shimcache location** HKLM\SYSTEM\CurrentControlSet\Control\SessionManager\AppCompatCache
- **Recycle Bin** Vista+ stores $R and $I files under $Recycle.Bin\%SID%
- **Event logs** Application, System and Security logs
- **Log locations** .evt (XP) and .evtx (Vista+) in winevt\Logs
- **Useful event IDs** e.g. 4624 successful logon, 4720 account created

© Billy Forrest

Active Directory and WMI

- **NTDS folder** stores the Active Directory database and related files
- **NTDS location** %SystemRoot%\Windows\ntds (2003+)
- **Common files** ntds.dit, edb.log, edb.chk, res1.log, res2.log
- **Registry key** HKLM\SYSTEM\CurrentControlSet\Services\NTDS\Parameters
- **WMI** core Windows management; start processes, schedule tasks, query logs
- **WMIC** command-line interface; wmic.exe /node:computername for remote use

© Billy Forrest

Archive formats and file signatures

Format	Hex header (signature)
ZIP	50 4B 03 04
RAR v4.x	52 61 72 21 1A 07 00
RAR v5.x	52 61 72 21 1A 07 01 00

- **Signature analysis** identifies the true file type from known header values
- **HxD editor** a hex editor used to inspect raw file headers

© Billy Forrest

Browser artefacts

- **Forensic value** visited URLs, search queries, cache, cookies, bookmarks
- **Additional data** form history, downloads, saved credentials
- **Web history** stores URL, title, timestamps and visit counts
- **Cache** improves loading speeds; acts as temporary storage
- **Internet Evidence Finder** commercial tool for live and dead browser examinations
- **Browsing History View** NirSoft tool supporting multiple browsers

© Billy Forrest

PE files, Office documents and PDF

- **Portable Executable (PE)** the Windows executable format, parsed by tools like PEDump
- **Office documents** macros can be directly malicious or unpack payloads
- **File names** .docx versus .docm reveal whether macros are enabled
- **PDF** can carry JavaScript and embedded actions
- **PDFiD** scans PDFs for suspicious keywords and JavaScript
- **Email files** Exchange and PST structures analysed with libpff, libpst and viewers

© Billy Forrest

The Windows registry — hives and files

Hive	Holds
HKLM (Local Machine)	System-wide settings; contains SAM, SECURITY, SOFTWARE, SYSTEM
HKCU (Current User)	Settings for the currently logged-on user
HKCR (Classes Root)	File-type associations and COM registration
HKU (Users)	Settings for all loaded user profiles
HKCC (Current Config)	Current hardware profile configuration

© Billy Forrest

Registry persistence and analysis

- **On-disk hive files** SYSTEM, SAM, SECURITY, SOFTWARE, DEFAULT, NTUSER.DAT
- **Startup keys** Run keys and RunOnce reveal programs that launch at logon
- **Persistence hunting** malware registers itself under startup keys to survive reboot
- **ProfileList** HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\ProfileList lists SIDs
- **Registry monitors** RegMon-style tools observe live registry activity
- **Shimcache** the AppCompatCache is itself a registry-stored artefact

© Billy Forrest

Identifying suspect files — hashing and strings

- **Hash tables** compare file hashes against known-good and known-bad sets
- **NSRL** National Software Reference Library of known unmodified software
- **HashKeeper** drug-intelligence hash set of known good and bad files
- **MD5 sets** user-generated and maintained hash collections
- **Strings** searching for known strings and commands in scripts and files
- **Obfuscation** hex-encoded strings and JavaScript unescape() hide the real text

© Billy Forrest

Packed executables, fuzzy hashing and permissions

- **Packed executables** small hidden payloads that unpack at runtime
- **Identified by** few imports, little automated code discovery, unusual section names and sizes
- **Fuzzy hashing** rolling hashes hint at the amount of change and identify similar files
- **Disadvantages** falls over with many changes; slow and computationally intensive
- **File permissions** NTFS permissions — read, write, read & execute, modify, full control

© Billy Forrest

The range of storage media

- **Hard drives** magnetic platters; SATA, PATA/IDE and SCSI interfaces
- **Solid-state drives** flash-based; wear-levelling affects data recovery
- **Removable media** USB pens, memory cards, CDs and DVDs
- **RAID arrays** multiple drives combined; imaging must preserve the array
- **Write blocking** hardware write blockers are essential for any source drive
- **Interfaces** SATA/PATA/IDE/SCSI adaptors are part of the grab pack

© Billy Forrest

Memory analysis with Volatility

- **Volatility** the open-source memory analysis framework
- **Profiles** e.g. --profile=Win7SP0x86 to match the memory dump
- **Processes** list running processes and identify parent/child relationships
- **DLLs** dlllist enumerates DLLs loaded into a process
- **Sockets and connections** reveal rogue listeners and remote connections
- **Hidden processes** dlllist with an offset can inspect hidden processes

© Billy Forrest

Memory artefacts worth hunting

- **Clipboard contents** may hold copied passwords or file-path artefacts
- **Encryption passwords** TrueCrypt passphrases can be recovered from RAM
- **Command prompt history** commands from terminated shells and console buffers
- **Browser history** recover malicious URLs, timestamps and response headers
- **Network connections** sockets and connections point to C2 infrastructure
- **Correlation** match memory artefacts with on-disk applications

© Billy Forrest

DISCUSSION

A user reports a slow machine and you find a Prefetch entry for a tool you did not expect. Which artefacts would you examine next to reconstruct what happened, and why?

Consider what ran, what was deleted, where a hostname may have been redirected, and how the process persisted.

Each artefact answers a different question; correlation across them reconstructs the timeline.

© Billy Forrest

CONSOLIDATION · GROUP E

Session 10 at a glance

Ref	Topic	Core idea
E4	Windows file structure	Prefetch, shadow copies, pagefile, hibernation, hosts, logs
E5	Application file structures	Archives, browsers, PE, Office, PDF, email, logs
E6	Registry essentials	Hives, on-disk files, startup keys for persistence
E7	Identifying suspect files	Hash tables, strings, packed files, fuzzy hashing
E8	Storage media	HDD, SSD, removable, RAID and write blocking
E9	Memory analysis	Volatility; processes, DLLs, sockets, clipboard

© Billy Forrest

KEY TAKEAWAYS

- **File structure is evidence** Prefetch, shadow copies, pagefile and hibernation hold the past
- **Application artefacts** browser history, Office macros and PDFs carry attacker activity
- **The registry persists** hives and startup keys reveal how malware survives reboot
- **Suspect files are found** via hash tables, strings, packing and fuzzy hashing
- **Memory is the richest source** Volatility exposes processes, DLLs, sockets and secrets

© Billy Forrest

QUIZ

Consolidation quiz (Group E: structure, registry, memory)

- Which registry hive is a registry-stored artefact of program execution?
- What does the Volatility dlllist plugin enumerate?
- Which file links hostnames to IP addresses and is vulnerable to hijacking?
- Which NTFS permission grants the most control over an object?
- What does the Prefetch file record about an application?

Answers in the session quiz — aim for 70%+ before leaving.

© Billy Forrest

NEXT SESSION

Next session: Analysing Host Intrusions III

- Infection vectors: executables, documents, JavaScript, drive-by downloads
- Malware behaviours and anti-forensic techniques
- Rootkit identification: hooking, IAT, EAT and SSDT
- Live malware analysis in the sandbox

Reading: Knowledge Group E source material.

© Billy Forrest



MY CYBER ACADEMY

Session 11 of 14

CREST Practitioner Intrusion Analyst (CPIA)

Analysing Host Intrusions III: Infection, Malware & Rootkits

How malware arrives, what it does, how it hides, and how to analyse it live.

GROUP E | INFECTION VECTORS | MALWARE | ROOTKITS

© Billy Forrest

Session 11 covers E10 to E13

Ref	Skill area	Assessment
E10	Infection Vectors	MC P
E11	Malware Behaviours and Anti-Forensics	MC
E12	Rootkit Identification	MC
E13	Live Malware Analysis	MC P

© Billy Forrest

SESSION OBJECTIVES

By the end of this session you will be able to

- **Describe infection vectors** executables, documents, JavaScript, drive-by downloads and email
- **Explain malware behaviours** and the anti-forensic techniques they use
- **Identify rootkits** through hooking, IAT, EAT and SSDT analysis
- **Explain Trojan components** exploits, downloaders, droppers and binders
- **Perform live malware analysis** in a controlled sandbox environment

© Billy Forrest

Infected executables, DLLs and documents

- **Infected executables** a payload injected into an expected friendly program
- **Masquerading** malware disguised as a trusted application
- **Infected DLLs** a small infection gives multiple executions
- **DLL hijacking and side-loading** malicious DLL loaded in place of a legitimate one
- **Documents and macros** macros directly malicious or unpacking payloads
- **File names** .docx versus .docm reveal macro capability

© Billy Forrest

JavaScript, drive-by downloads and passive exploitation

- **JavaScript** notoriously insecure; allows code to run in the browser
- **Drive-by downloads** install software without the user's knowledge
- **Also called drive-by installation** used by rogue-antivirus software
- **Reliant on compromised websites** e.g. the Mac Flashback exploit
- **Passive exploitation** waits for a target; hunter versus snare
- **Malicious file-sharing sites** a snare countered by search engines and browsers

© Billy Forrest

USB, shared drives and email attacks

- **USB and external media** shared between users; found drives; BadUSB; AutoRun
- **CDs and DVDs** another removable-media infection path
- **Shared drives** multiple access from trusted sources; potentially internet-facing
- **Email-based attacks** social engineering manipulates users through psychology
- **File-name tricks** e.g. Not_a_virus.jpg.exe hides the real extension
- **Defence mechanisms** spam filters and user training

© Billy Forrest

DISCUSSION

Which infection vector would you consider most likely for a targeted intrusion against a financial firm, and how would the evidence differ from a broad phishing campaign?

Weigh spear-phishing and document macros against drive-by downloads and USB vectors, and think about what artefacts each leaves behind.

The vector chosen shapes which host artefacts an analyst should prioritise.

© Billy Forrest

Malware behaviours to look for

- **Persistence** registry Run keys, services and scheduled tasks
- **Command and control** C2 channels outbound to attacker infrastructure
- **Propagation** spread across the network via shares and credentials
- **Data exfiltration** staging and transmitting stolen data
- **Privilege escalation** gaining higher rights on the host
- **Defence evasion** disabling AV, hiding processes and files

© Billy Forrest

Anti-forensic techniques

- **Timestomping** altering file timestamps to break the timeline
- **Log deletion** clearing event logs and audit trails
- **Data hiding** Alternate Data Streams and hidden files
- **Obfuscation** packing and encrypting the payload
- **Artifact wiping** clearing Prefetch, shadow copies and browser history
- **Detection avoidance** shunning analysis environments and sandboxes

© Billy Forrest

What is a rootkit?

- **Rootkit** malware that hides its presence from the operating system
- **Trojan horse components** exploit, rootkit, downloader, dropper and binder
- **Symptoms** system lockups, unauthorized changes, network glitches
- **Polymorphism** changes appearance while keeping core functionality
- **Makes detection harder** polymorphism is not specific to rootkits but complicates finding them

© Billy Forrest

Types of rootkit

Type	Description
User-mode	Runs at the application layer, intercepting API calls
Kernel-mode	Runs at ring 0, intercepting system calls and drivers
User/kernel hybrid	Combines both to maximise control
Firmware rootkit	Hides within device firmware such as the BIOS
Virtual rootkit	Runs as a hypervisor beneath the operating system

© Billy Forrest

Hooking techniques: IAT and EAT

- **Two types of Windows hooks** local and remote
- **IAT** Import Address Table — the functions a program imports
- **IAT hooking** redirecting an imported function to malicious code
- **EAT** Export Address Table — the functions a DLL exports
- **EAT hooking** redirecting exported functions to intercept calls
- **Inline API hooks** patching the start of a function to jump elsewhere

© Billy Forrest

Detecting IAT hooks

1. **Enumerate active processes**
   walk the list of EPROCESS structures
2. **Enumerate loaded DLLs**
   examine the PEB or VAD; record names, base addresses and sizes
3. **Dump and rebuild**
   dump the process and loaded DLLs to parse the PE header and locate the IAT
4. **Verify function addresses**
   check each imported function address falls within the owning DLL

© Billy Forrest

SSDT hooking

- **SSDT** System Service Descriptor Table (or Dispatch Table)
- **Kernel hooking** rootkits patch SSDT entries to hide files, processes and connections
- **Detecting SSDT hooks** compare table entries against the original kernel addresses
- **Kernel-mode rootkits** operate at ring 0 where they have the most control
- **Impact** can hide malicious processes and intercept network activity

© Billy Forrest

User-space keyloggers

- **Typically use the Windows API** calling SetWindowsHookEx to install a hook
- **SetWindowsHookEx parameters** idHook, lpfn, hMod and dwThreadId
- **WH_KEYBOARD and WH_KEYBOARD_LL** low-level keyboard hooks
- **Hook injection** the hook function receives each keystroke
- **Other hook types** inline API hooks and driver IRP hooks

© Billy Forrest

Live malware analysis in the sandbox

- **Controlled environment** an isolated VM or sandbox, snapshot before execution
- **Process monitoring** observe process creation and parent/child relationships
- **File and registry monitoring** see what the sample creates and modifies
- **Network monitoring** capture C2 connections and DNS lookups
- **Do not remediate** identify behaviour, do not clean during analysis
- **Multiple tools** cross-check results across several monitors

© Billy Forrest

TOPIC E13 · LIVE ANALYSIS

The live analysis workflow

1. **Prepare the environment**
   a clean, snapshot-able sandbox that mirrors the target
2. **Execute the sample**
   run it and observe its immediate actions
3. **Monitor behaviour**
   processes, files, registry, network and services
4. **Collect artefacts**
   capture logs, dumps and network traffic
5. **Analyse and report**
   document the behaviour and its indicators of compromise

© Billy Forrest

CONSOLIDATION · GROUP E

Group E at a glance

Ref	Topic	Core idea
E10	Infection vectors	Executables, DLLs, macros, drive-by, USB, email
E11	Malware behaviour & anti-forensics	Persistence, C2, timestomping, log deletion
E12	Rootkit identification	IAT, EAT, SSDT hooking; keyloggers
E13	Live malware analysis	Sandbox, process/file/network monitoring

© Billy Forrest

KEY TAKEAWAYS

- **Infection vectors are varied** executables, DLLs, macros, drive-by, USB and email
- **Malware behaves and hides** persistence, C2, and anti-forensics like timestomping
- **Rootkits hook the system** IAT, EAT and SSDT hooking hide the malware
- **Keyloggers use the API** SetWindowsHookEx and low-level keyboard hooks
- **Analyse malware live** in a sandbox, monitoring process, file and network activity

© Billy Forrest

QUIZ

Consolidation quiz (Group E: infection, malware, rootkits)

- Which table lists the functions a program imports and can be hooked?
- What technique changes a file's timestamps to break the timeline?
- Which Windows API call installs a keyboard hook?
- Which infection vector installs software without the user's knowledge?
- Where does a kernel-mode rootkit operate?

Answers in the session quiz — aim for 70%+ before leaving.

© Billy Forrest

NEXT SESSION

Next session: Reverse Engineering Malware I

- Introduction to reverse engineering and the analyst's toolkit
- Anti-reverse-engineering techniques used by malware
- Analysing malware functionality and behaviour
- Preparing for the practical reverse-engineering components

Reading: Knowledge Group F source material.

© Billy Forrest